

07 · Data Governance & OCAP / Indigenous Data Sovereignty

This document explains **how the platform treats data** — what it collects, what it deliberately does *not*, where that data lives, who can reach it, and how those choices line up with **OCAP®** (Ownership, Control, Access, Possession) and Indigenous data sovereignty.

It is written to be honest about the difference between what is **built and running**, what is **designed but deferred**, and what is a **principle we hold but cannot fully enforce in software yet**. For a mission-led owner accountable to Indigenous communities, that honesty matters more than a clean checklist.

Companion documents: [01 · Project Audit](#), [04 · Monitoring & Security](#), [06 · RAP Research](#), [08 · Content Stewardship](#), [09 · Product Roadmap](#). Unfamiliar terms (Bedrock, KMS, BN, ABAC, ...) are defined in the [README](#) glossary.

0 · The honest headline (read this first)

Three things to hold in mind before the detail:

1. **Sovereignty here is achieved mostly by *not collecting sensitive data***. The platform indexes organizations' **own public disclosures**; sensitive Indigenous community data is deliberately kept out and stays with communities and the client. This is the strongest, most real part of the governance story — and it is stated identically in the code, the data-verification doc, and the legal-cases methodology page.
2. **Canadian *hosting* is designed; strict in-country *AI inference* is not possible today**. Data can rest in Canada (`ca-central-1`), but Amazon's Bedrock models are **not hosted in Canada**, so the AI-reading step routes to a US/global region regardless of settings. **Hosting ≠ inference**. We do not represent the platform as doing in-country inference, and neither should you.
3. **The governance *enforcement* layer is largely designed, not yet built**. One piece — an automatic data-classification tag — is live. The rest (encryption with a customer key, per-class access controls, an access-audit log, a consent record, and the actual move to `ca-central-1`) is an approved design that has **not been implemented**. See Part G and [09 · Roadmap](#).

None of this is a problem *today* because **all current production data is public** — there is no sensitive data at risk. These become requirements the moment the platform ingests private, org-submitted, or community-linked material.

Part A · The core principle: sovereignty by data minimization

The platform's first line of defense is what it refuses to hold.

- **Only public disclosures are indexed**. Every sourced commitment comes from an organization's own public reconciliation / ESG / supplier page or first-party news release. The seed data says so in plain terms: "*These are the companies' **public commitments** — NOT sensitive Indigenous data (which stays with communities / the client).*"

- **The same rule is repeated** in the data-verification register (“*public disclosures only ... deliberately **not** sensitive Indigenous community data*”) and on the legal-cases methodology page (“*public court records only ... community-sensitive material kept out of third-party pipelines*”).
- **Correcting an earlier misconception:** the dashboard’s ~100 organizations are **real, genuine Canadian organizations**, hand-curated from real public sources (see [06 · RAP Research](#) and [DATA_VERIFICATION.md](#)) — not fabricated, and not sensitive community data. The figures are *illustrative snapshots* from the cited sources.

For an Indigenous-led owner, this is the point to lead with: the platform is built to make companies’ *public promises* legible and trackable, without becoming a store of sensitive community information.

Part B · OCAP®, mapped to what actually runs

OCAP has four principles. Here is where each is genuinely honored in code — and where it is a design we haven’t yet implemented.

OCAP principle	What runs today ✓	What is designed, not built ◦
Ownership	Data is companies’ own public disclosures; org identity is anchored to a real legal entity (Business Number).	—
Control	Records are soft-deleted, never hard-deleted (“withdraw,” not erase); a company controls whether its self-report appears publicly (opt-in, default off).	A per-upload consent record (who may access/query/cite) is spec’d but not implemented.
Access	A party can export everything about them via a self-service endpoint; access to that export is restricted to the party or Institute staff.	A CloudTrail access-audit log (who-touched-what) is designed but not built.
Possession	Data rests in AWS accounts the client will own; production has deletion-protection; the design targets ca-central-1 .	The actual ca-central-1 migration , a customer-managed encryption key (KMS) , and per-data-class IAM controls are deferred.

The classification tag that *is* built. Every piece of RAP data carries a `dataClass` of `public` or `org_submitted`. The classifier is deliberately **fail-closed**: a submission is only ever `public` when Institute staff explicitly declare it so — *a company cannot mark its own submission public* (closing the greenwashing incentive), and anything unrecognized is treated as private. This tag is threaded through every write path. What it does **not** yet do is drive encryption or access control — nothing consumes the tag for enforcement yet. It is the hook the deferred controls will hang on.

Part C · Data residency — the honest hosting-vs-inference story

This is the question an Indigenous-data-sovereignty audience will ask first, so state it precisely.

- **Where data can rest:** the platform is built so a Canadian (`ca-central-1`) stack can be deployed for data residency — the region is a one-line switch. **Today, production still runs in us-east-1, and all of its data is public**, so there is no residency violation; the Canadian migration is a *pre-emptive* design step, not yet executed (see Part G).
 - **The legal-cases corpus stays in us-east-1 on purpose.** Those are **public court decisions** (public by construction), and their ~43,000-case search index is already built in `us-east-1`; moving it would be a large re-indexing job for zero sovereignty benefit.
 - **AI inference leaves Canada — unavoidably, today.** Amazon Bedrock has **no Canadian inference geography** (there is no `ca.` model profile in AWS’s catalogue at all). So the AI-reading step routes to a US/global profile *regardless of where data rests*. You can keep data-at-rest and even document-OCR in Canada; the LLM inference step still leaves the country. **Do not describe this as in-country inference.** Closing that gap requires a Canada-hosted model — e.g. a future TELUS partnership or a self-hosted model (see [09 · Roadmap](#)).
-

Part D · What data the platform holds

Business data (DynamoDB tables): the confirmation engine (companies’ reported supplier spend and suppliers’ confirmations), the RAP survey, the public commitments Index, the alignment domain, the notifications digest, and the RAP-extraction canonical data. Public court cases live in a separate `us-east-1` table.

Personal data (kept minimal): - **Login credentials** — email + password. Passwords are stored **script-hashed** (meeting the OWASP minimum), never in plain text. - **Session cookie** — a signed token carrying the user’s role and email (for audit/display). - **Company self-submissions** — first-party commitment entries by a logged-in company. - **Uploaded RAP documents** — the PDFs a company or curator uploads, stored in a private S3 bucket (browser-to-S3 via a short-lived signed URL; the bucket blocks all public access).

Deliberately not held: sensitive Indigenous community data (Part A). There is currently **no personal data beyond logins** — no end-user tracking, no community records.

Part E · How trust and provenance are governed

Governance is not only about storage — it is about never *overstating* what the data means. Several real mechanisms enforce this (all detailed in [06](#)):

- **Tiered evidence — confirmed > research > self-reported.** A self-report can never be auto-promoted to “confirmed.” Only independent supplier attestation can do that; a company’s own “we met this” is capped at “reported.” Self-reports also don’t count toward headline figures and only appear publicly on **explicit opt-in**.
- **Locate-and-quote grounding.** Every AI-extracted fact must cite a verbatim quote and page from the source, or it is discarded — the model locates and quotes, it never guesses.

- **Human confirmation before anything becomes canonical**, with a per-field record of what a reviewer checked against the source.
 - **Identity is attested and anchored**. A company can only claim an organization with **both** an explicit authorization attestation **and** a Business-Number match — “never silently, never unattested.” (Caveat: the live business-registry check is currently a **stub** — see Part G.)
-

Part F · Security posture relevant to governance

Detailed in [04 · Monitoring & Security](#); the governance-relevant facts:

- **The web firewall (WAF) is in watch-only (count) mode — it blocks nothing yet**. Flipping it to blocking is a one-setting change after an observation window (see [09 · Roadmap](#)).
 - **Backups are partial**. Point-in-time recovery is enabled on the main RAP data table **only**; the other tables have none. A real Canadian residency environment should extend this.
 - **Encryption at rest is AWS-default only**. No customer-managed key (KMS) exists yet — that’s part of the deferred governance work.
 - **Demo authentication is insecure by design**. All demo logins share one publicly-documented password; this is a showcase posture and must be replaced before real use (purge + rotate — see [08 · Content Stewardship](#)).
-

Part G · What a sovereignty-minded owner must know (the honest gaps)

These are the things to be candid about with your community and your board:

1. **AI inference leaves Canada today** — a Bedrock limitation, not a code gap. In-country inference needs a Canada-hosted model (Part C).
2. **The ca-central-1 migration is not done**. Only the classification *tag* (Phase 1) is built; the region move, customer-managed encryption, per-class access controls, and access-audit log are an **approved design, deferred** (Part B).
3. **No consent record or access-audit log exists yet** — the enforcement half of Control/Access.
4. **Business-registry verification is a stub** — until activated, “registry-verified” means “matched a built-in list,” not a live government lookup (federal corporations only).
5. **No enforced access control on private data** — the `dataClass` tag exists but nothing consumes it; access is app-layer session checks only. Fine while all data is public; a gap the moment it isn’t.
6. **Demo auth, count-mode WAF, and partial backups** must be closed before real users and real data.
7. **No formal Privacy Impact Assessment (PIA)** has been produced — the governance work is an engineering design, not a privacy/legal assessment. Commissioning one is worth considering before ingesting any personal or community-linked data.

Every one of these is tracked as a concrete item in [09 · Product Roadmap](#).

*This document reflects the repository as handed off. The governance design it summarizes lives at `docs/superpowers/specs/2026-07-15-data-governance-ocap-residency-design.md` (its own status line: “Phase 1 built and merged; Phases 2–5 deferred”), with the classification code in `src/lib/governance/`. The single most important takeaway is the one that is fully real today: the platform earns its sovereignty posture chiefly by **not collecting sensitive community data** — a principle enforced by convention and fail-closed classification, and one worth protecting as the product grows.*